

SKINSYNC AI INC.

AGREEMENT B

PRIVACY POLICY

Controlled draft • Effective date: August 23, 2026

Effective date: August 23, 2026

1. Information Collected SkinSync may collect account/contact data; health intake such as allergies, medications, medical history, prior procedures, pregnancy or treatment considerations; facial images, scan frames, progress photos, facial mapping, geometry, landmarks, measurements, skin texture and visible-feature descriptions; Treatment Journeys, simulations, preferences and notes; clinic-share records; clinic and post-treatment records; device, security, transaction, and consent records.

2. Sources and Roles Sources include the user, device, selected or sponsoring clinic, service providers, and SkinSync-generated inferences. SkinSync may act directly for the consumer in one workflow and as a clinic's HIPAA Business Associate in another. Records are classified and logically segregated by role, clinic tenant, patient, purpose, and authorization.

3. Purposes • Create and secure accounts and authenticate users. • Collect user-authorized intake; process scans; generate and compare simulations and Treatment Journeys. • At the user's direction, transmit the exact authorized report to a named clinic and provide a receipt. • Support clinic-directed intake, consultation, scheduling, communications, treatment documentation, and post-treatment follow-up. • Operate, debug, audit, secure, and improve reliability using data minimized for the task. • Comply with law, respond to rights requests, investigate incidents, and protect users and systems.

4. No Identifiable Training, Sale, or Health Advertising SkinSync does not sell consumer health or biometric data, does not use it for cross-context behavioral advertising, and does not use identifiable health data, facial images, biometric information, or PHI for generalized or cross-customer AI training. Service providers may process minimum necessary information only for contracted services under appropriate restrictions.

5. Clinic Disclosures For an independent consumer share, SkinSync displays the clinic legal identity, location, exact data manifest, purpose, expiration, and limitations before obtaining the required affirmative actions. Other private options are excluded. Clinic-connected disclosures may also occur for treatment, payment, health-care operations, or contracted services as permitted by HIPAA, the BAA, the clinic's notice, and applicable law.

6. Retention Facial source images and biometric-derived data: Destroy when the disclosed purpose is satisfied or no later than three years after the last interaction,

whichever occurs first, unless a shorter rule controls or lawful clinic retention applies. Private non-final simulations and journeys: Until user deletion or 24 months of inactivity after advance deletion notice, unless needed for an active request. Clinic-specific PHI: As directed by the clinic and BAA; export and deletion after termination subject to law, documented infeasibility, and backup cycle. Consent, authorization, disclosure, and audit evidence: At least six years where HIPAA documentation rules apply; otherwise seven years or the longer period reasonably required to prove compliance. Security and access logs: Seven years unless risk analysis supports a different documented schedule. Backups: Isolated from ordinary use and overwritten within 90 days after primary deletion unless a documented legal or technical exception applies.

7. Security SkinSync applies HIPAA-aligned safeguards to identifiable health and biometric data, including encryption in transit and at rest, MFA, least privilege, tenant and object-level access controls, logging, secure development, vulnerability management, backups, incident response, vendor review, workforce training, and sanctions.

8. Rights and Appeals Subject to applicable law and exceptions, users may confirm processing; access, correct, download, or delete information; withdraw consent; obtain relevant recipient information; opt out of marketing, sale, targeted advertising, and qualifying profiling; and appeal a denial. Use in-app privacy controls or privacy@skinsyncai.com.

9. HIPAA and Clinics A record is PHI when it is created, received, maintained, or transmitted by a Covered Entity or by SkinSync on behalf of a Covered Entity or Business Associate. SkinSync's decision to apply HIPAA-aligned safeguards to all health data does not represent that every consumer record is legally PHI. A clinic's Notice of Privacy Practices governs its clinical record.

10. Adults Only; U.S. Service; Contact The launch Platform is limited to U.S. adults age 18 or older. SkinSync does not knowingly permit minors in the launch workflow. Contact privacy@skinsyncai.com, 9 N. Wabash Avenue, Chicago, Illinois 60602, 312-847-2424.